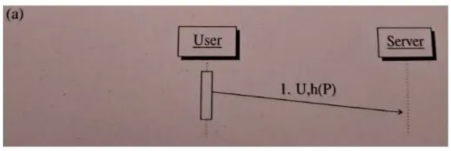
Giugno 2025

3 Security Protocols

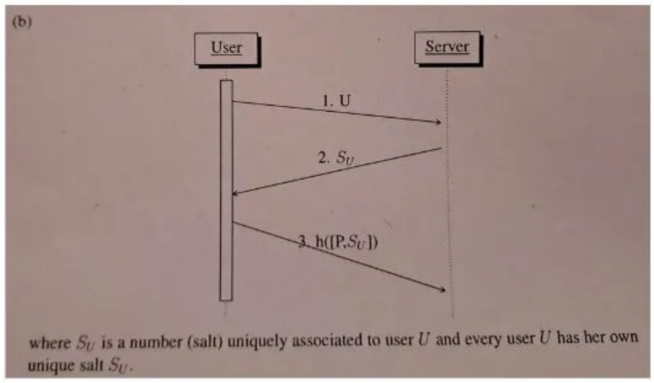
Consider the problem of authenticating users on a server. Users use robust[1] passwords P to authenticate on S. Which of the following authentication protocols would you recommend for this purpose? Please justify your answer and describe an attack on the authentication property for each vulnerable protocol.

Note: $h(\cdot)$ is a robust cryptographic hash function.



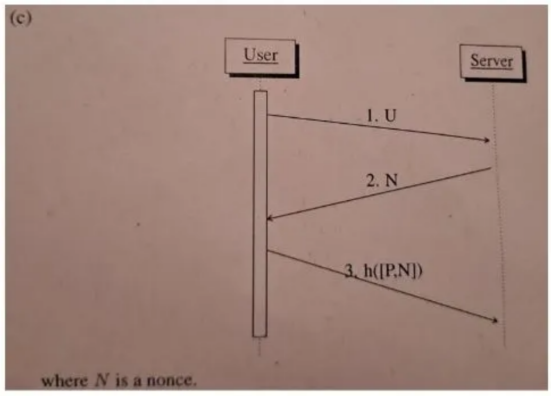
▼ Risposta

Risposta: Non si raccomanda questa versione del protocollo perchè la proprietà di autenticazione può esser violata da un attaccante che, origliando il messaggio 1, potrebbe fare un replay attack rimandando, in un secondo momento, il messaggio origiliato ed autenticandosi come U.



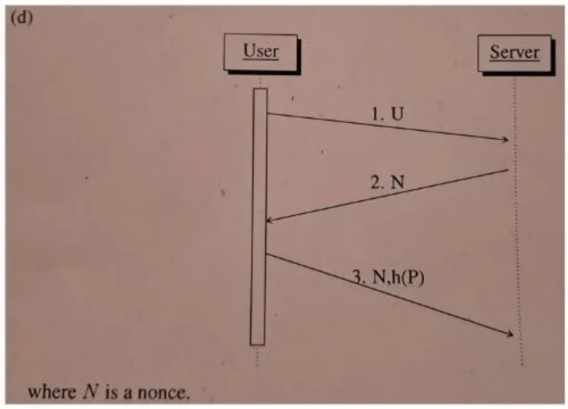
▼ Risposta

Risposta: Non si raccomanda neanche questa versione del protocollo nonostante sia più complessa, e per certi aspetti più sicura, della versione precedente in quanto rimane suscettibile agli attacchi di tipo replay. Essendo che il sale S_U non cambia mai ad un attaccante basterebbe origliare il messaggio 3 per poi usarlo per autenticarsi sul server come l'utente U in un secondo momento.



▼ Risposta

Risposta: Si raccomanda questa versione del protocollo in quanto la vulnerabilità legata al messaggio 3 è stata rimossa non essendo più statico ma dinamico ad ogni istanza del protocollo. Il server S manda un nonce come challenge all'utente U e questo viene concatenato come si faceva con il sale nella versione precedente, ma qui il nonce cambia ad ogni istanza del protocollo, quindi un eventuale attaccante che origlia il messaggio 3 non potrebbe riutilizzarlo in un secondo momento.



▼ Risposta

Risposta: Non si raccomanda questa versione del protocollo in quanto vulnerabile agli attacchi di tipo replay essendo che il nonce mandato come challenge dal server S viene passato in chiaro al messaggio 3, permettendo ad un attaccante di origliarlo, copiarsi $h(P)$, aprire una nuova istanza del protocollo con il server S, mandare U in chiaro, ricevere un nuovo nonce dal server e concatenarci l'hash della password, ottenendo così l'autenticazione sul server.

Febbraio 2025

SuperMail wants every email to be authenticated and protected from modification or tampering while it is transit from the sender to the receiver. Suppose Alice is sending an email M to Bob.

Given SuperMail's design constraints, which of the following options would be a secure way to protect the authenticity and integrity of her email?

(a) Alice's software should encrypt M under Bob's public key. In other words, Alice's soft-ware should send $E_{K_B}(M)$ to Bob.

▼ Risposta

Sbagliata. Non verifica l'autenticità nè l'integrità non avendo Bob alcun metodo per confrontare il messaggio con altre info, quindi il messaggio M potrebbe arrivare con dei bit in meno oppure modificati a causa di un canale di comunicazione rumoroso. Il messaggio potrebbe venir totalmente sostituito da un altro messaggio M' scritto da un utente diverso da Alice e poi cifrato con la chiave pubblica di B, ossia K_B , conosciuta da tutti per definizione, e quindi Bob non avrebbe alcun modo per verificare chi è l'autore del messaggio.

(b) Alice's software should send M along with a digital signature on M using Alice's private key. In other words, Alice should send $M||E(K_A^{-1}, h(M))$.

▼ Risposta

Corretta. L'autenticità è garantita dalla cifratura dell'hash del messaggio con la chiave privata di A, ossia la sua firma, questo assicura non repudiabilità e, quindi, autenticazione. Vi è anche integrità in quanto è presente l'hash, ossia il fingerprint, del messaggio, che non può essere modificato da nessuno ma, al massimo, letto.

(c) Alice's software should choose a new symmetric key k for this email, send an encryption of k under Bob's public key, and also send an encryption of M under k using a stream cipher such as RC4. In other words, Alice should send $E(K_B, k)||M \oplus RC4(k)$.

▼ Risposta

Sbagliata. Non verifica l'integrità per lo stesso motivo indicato nel punto (a). Non verifica neanche l'autenticità perchè non ci sono identificativi o firme, quindi Bob non ha modo di sapere se il messaggio proviene da Alice. Oltre al problema della perdita di dati, un attaccante potrebbe generare una chiave k' diversa da k , cifrarla con la chiave pubblica di Bob, $E(K_B, k')||M' \oplus RC4(k')$ e modificare anche il messaggio in chiaro M con M' .

(d) Alice's software should choose a new symmetric key k for this email. Then it should send four pieces of information: the message M, a MAC on M under the key k, an encryption of k under Bob's public key, and a digital signature on k using Alice's private key. In other words, Alice should send $M||MAC_k(M)||E(K_B, k)||E(K_A^{-1}, k)$.

▼ Risposta

Sbagliata. Non verifica l'autenticità in quanto la chiave k è visibile a tutti spaccettando l'ultima parte del messaggio con la chiave pubblica di Alice: $M'||MAC_k(M')||E(K_B, k)||E(K_A^{-1}, k)$.

il messaggio M è modificabile senza che Bob se ne possa accorgere, il quale può solo verificare che il messaggio li sia arrivato integro.

Extra: per sistemare il messaggio d, Alice avrebbe dovuto inserire la fingerprint, ottenuta con il MAC del messaggio, dentro il messaggio cifrato con la sua chiave privata, oppure inserire la sua firma insieme alla cifratura di k nel messaggio cifrato con la chiave pubblica di B.

Febbraio 2024

3. Security Protocols

Consider the following authentication protocol

1. $A \to B : A$
2. $B \to A : B, N_B$
3. $A \to B : E(K, [A, B, N_B])$

nonce = number used once

where K is a key shared between A and B, N_B is a nonce generated by B and $E(K, M) = K \oplus M$. (We thus assume that the length of the key K is equal to length of the bitstring obtained by concatenating the bitstrings representing A, B, and N_B.)

(a) The protocol is used by B to authenticate A. Does the protocol achieve this goal? Please justify your answer.

$K \oplus [A, B, N_B] \oplus A, B, N_B$

▼ Risposta (a)

Il protocollo **NON** raggiunge il suo obiettivo in quanto B non sarebbe in grado di autenticare A nel caso in cui un attaccante C si mettesse in mezzo alla comunicazione con un attacco di tipo Man-in-the-middle origliando i messaggi 1 e 2 in chiaro, intercettando e decriptando il messaggio 3 ricavando, così, la chiave condivisa K tramite l'operazione $K \oplus [A, B, N_B] \oplus A, B, N_B$ e sostituendo l'identificativo di A con il suo nel messaggio 3 inviandolo poi a B.

(b) Now consider the protocol consisting of the following single step:

1. $A \to B : E(K, [A, B, T_A])$

where K is a key shared between A and B, T_A is a time-stamp generated by A, and $E(K, M) = K \oplus M$. (As above, we thus assume that the length of the key K is equal to length of the bitstring obtained by concatenating the bitstrings representing A, B, and T_A.) Upon reception of the message B must check that $T_A - T_0 < \epsilon$ where T_0 is the current value of its own clock and ϵ is a threshold that depends on the latency of the communication link. Similarly to the protocol in the previous question, this protocol is used by B to authenticate A. Does the protocol achieve this goal?

Please justify your answer.

▼ Risposta (b)

Il protocollo potrebbe raggiungere il suo obiettivo se si presuppone che gli orologi del mittente e del destinatario siano sincronizzati, che la soglia ϵ sia sufficientemente piccola da non permettere replay attack in caso di intercettazione e che l'attaccante non conosca gli identificativi A e B in chiaro.

Se un attaccante C conoscesse gli identificativi A e B in chiaro e la soglia ϵ fosse sufficientemente alta, intercettando il messaggio C potrebbe risalire a T_A sapendo che il messaggio è stato mandato da pochissimo, e a quel punto ricavarsi K conducendo un attacco di tipo Man-in-the-middle simile a quanto visto nell'esempio precedente, sostituendo l'identificativo di A con il suo e mandando tutto a B entro il tempo concesso dalla soglia ϵ.

Gennaio 2024

4. Security Protocols

The following key exchange protocol has been designed to allow A to guess and share a new (i.e. fresh) session key K with B. Server S is is assumed to be trustworthy and the publioc key of S, namely K_S, is the only public key that A knows in advance.

1. $A \to S : A, B$
2. $A \leftarrow S : E(K_S^{-1}, [A, K_A]), E(K_S^{-1}, [B, K_B])$
3. $A \to B : E(K_B, [K, N_A])$
4. $A \leftarrow B : E(K, [K, N_A])$

where N_A is a nonce.

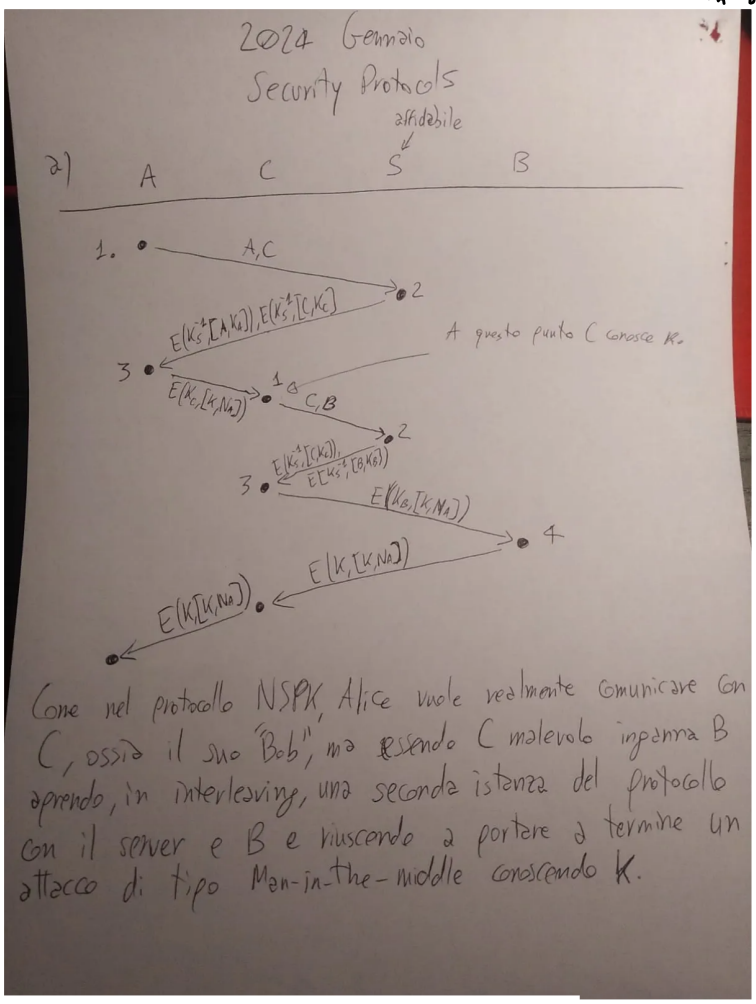
(a) Show that the protocol does not meet its design objetives by presenting an attack.

1. $A \to S : A, C$
2. $S \to A : E(K_S^{-1}, [A, K_A]), E(K_S^{-1}, [C, K_C])$
3. $A \to C : E(K_C, [K, N_A])$
4. $C \to S : C, B$
5. $S \to C : E(K_S^{-1}[C, K_C]), E(K_S^{-1}, [B, K_B])$
6. $C \to B : E(K_B, [K, N_A])$
7. $B \to C : E(K, [K, N_A])$
8. $C \to A$; "

(b) Show how would you fix the procol by modifying step 3.

$A \to B : \{K, N_A\}_{K_B}$

$A \to B : \{C_A, \{K, N_A, T\}_{K_A^{-1}}\}_{K_B}$



Luglio 2023

3. Protocolli di Sicurezza

Consider the following protocol:

1. $C \to AS : C, S, N_c$
2. $AS \to C : AS, \{AS, C, N_C, K_S\}K_{AS}^{-1}$

where a client **C** wants to communicate with a server **S** and wants to be sure it is indeed doing it with **S**.
Since **C** does not have a public key of **S**, **C** asks an Authentication Server **AS** to get it.
Of course, we assume that **C** has the public key of **AS**, namely K_{AS} .

(a) Show that the protocol is unsecure by describing how it can be attacked.

▼ Soluzione

MAN IN THE MIDDLE:

Un attaccante intercetta il primo messaggio e modifica il secondo identificativo con il suo:

1. $M \to AS : C, M, N_c$

ed il server di autenticazione risponderà con la chiave pubblica dell'attaccante:

2. $AS, \{AS, C, N_C, K_M\}K_{AS}^{1}$

Il client C stabilirà una connessione con M pensando di star parlando con S.

(b) Explain why the protocol is vulnerable and propose a patched version of the protocol.

▼ Soluzione

Modifica proposta:

1. $C \to AS : C, S, N_c$
2. $AS \to C : \{AS, S, N_C, K_S\}_{K_{AS}^{-1}}$
3. $C \to S : \{C, N_C, \text{firma}(C, N_C)\}_{K_S}$

Spiegazione:

- **AS** verifies the signature of client **C** using **C**'s public key.
- If the verification is successful, **AS** responds to **C** with the message $AS, \{AS, C, N_C, K_S\}K_{AS}^{1}$.

▼ Soluzione 2

Modifica proposta:

1. $C \to AS : C, S, N_c$
2. $AS \to C : \{AS, C, N_C, S, K_S\}_{K_{AS}^{-1}}$

Spiegazione:

Ora il client C ha anche l'identificativo del server S e l'attacco Man-in-the-middle non è più possibile potendo C verificare a chi appartiene la chiave pubblica che lui pensa essere del server.

Giugno 2023

The **CRAM-MD5** (Challenge-Response Authentication Mechanism) protocol, used to provide authentication for the **IMAP4** email protocol, consists of the following steps:

1. $C \rightarrow S : C$ *(Client sends a request to Server)*
2. $S \rightarrow C : N||T||S$ *(Server responds with Nonce, Timestamp, and Server identifier)*
3. $C \rightarrow S : U, H(K||T)$ *(Client sends Username and Hash of the Key and Timestamp)*

Where:

- **C** = Client
- **S** = Server
- **N** = Nonce (a random number)
- **T** = Timestamp
- **U** = Username
- **K** = Cryptographic key derived from the user's password
- **H** = Cryptographic hash function (MD5)

The goal of the protocol is to allow **S** to authenticate **C**. It is assumed that **S** knows **K**.

1. **Is the timestamp T necessary? Please justify your answer.**

   ▼ Risposta

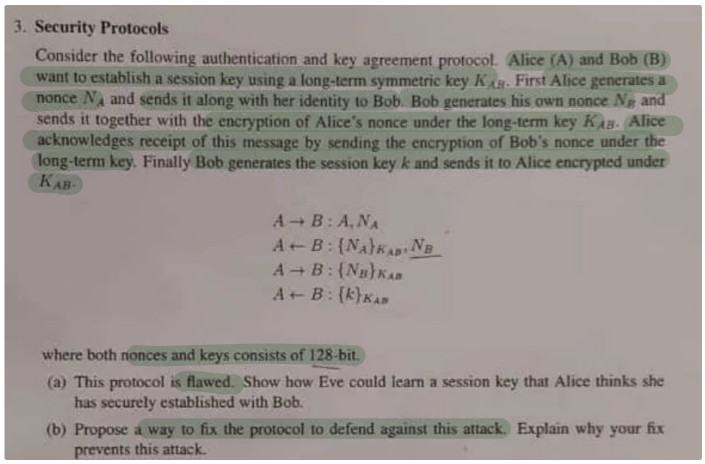
   Sì. Il timestamp è necessario per evitare attacchi di tipo replay e reflection. Senza il timestamp un attaccante potrebbe riutilizzare un precedente messaggio intercettato, considerato valido per l'autenticazione, in un secondo momento per ottenere un accesso non autorizzato.

2. **Is the nonce N necessary? Please justify your answer.**

   ▼ Risposta

   Non è strettamente necessario. Per com'è definito il protocollo, il nonce non viene usato per validare o autentificare nulla, viene solamente passato dal server al client nel messaggio 2, se fosse usato correttamente svolgerebbe la stessa funzione del timestamp. Può comunque tornare utile quando client e server non hanno entrambi degli orologi interni o questi non sono sincronizzati tra di loro, oppure per gestire più richieste (aka istanze di protocollo) simultanee nello stesso istante di tempo per identificarle univocamente.

Gennaio 2023



3. **Security Protocols**

Consider the following authentication and key agreement protocol. Alice (A) and Bob (B) want to establish a session key using a long-term symmetric key K_{AB}. First Alice generates a nonce N_A and sends it along with her identity to Bob. Bob generates his own nonce N_B and sends it together with the encryption of Alice's nonce under the long-term key K_{AB}. Alice acknowledges receipt of this message by sending the encryption of Bob's nonce under the long-term key. Finally Bob generates the session key k and sends it to Alice encrypted under K_{AB}.

$$A \rightarrow B : A, N_A$$
$$A \leftarrow B : \{N_A\}_{K_{AB}}, N_B$$
$$A \rightarrow B : \{N_B\}_{K_{AB}}$$
$$A \leftarrow B : \{k\}_{K_{AB}}$$

where both nonces and keys consists of 128-bit.

(a) This protocol is flawed. Show how Eve could learn a session key that Alice thinks she has securely established with Bob.

(b) Propose a way to fix the protocol to defend against this attack. Explain why your fix prevents this attack.

▼ Soluzione (a)

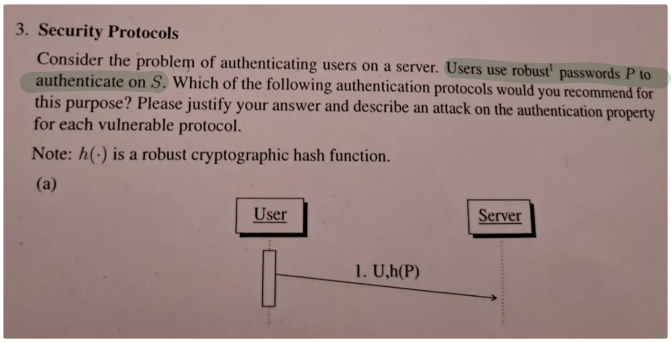
Eve può condurre un attacco misto con reflection attack e type flaw attack al terzo e quarto messaggio tagliando B fuori dalla comunicazione dato che i nonces e le chiavi hanno la stessa lunghezza in bit. Eve potrebbe riflettere il messaggio 3 ad Alice così com'è conoscendo N_B letto in chiaro al messaggio 2 intercettato, Alice confonderebbe k con N_B usandola come nuova chiave di sessione.

▼ Soluzione (b)

Esistono almeno 3 soluzioni diverse:

1. Cambiare la cardinalità dei nonces o delle chiavi così che il type flaw attack, e quindi, il reflection attack, non possono andare a segno.
2. Tipizzare gli elementi all'interno del messaggi, per esempio usando 2 bit concatenati all'inizio degli elementi, ossia 00/01/10/11 (00: identificatore, 01: nonce, 10: chiave, 11: timestamp).
3. Aggiungere un elemento all'interno dei messaggi cifrati (es. aggiungere l'identificatore al messaggio 2 e 3).

Febbraio 2023



3. **Security Protocols**

Consider the problem of authenticating users on a server. Users use robust[1] passwords P to authenticate on S. Which of the following authentication protocols would you recommend for this purpose? Please justify your answer and describe an attack on the authentication property for each vulnerable protocol.

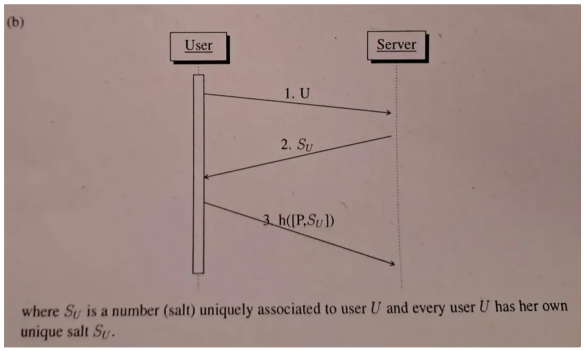
Note: $h(\cdot)$ is a robust cryptographic hash function.

(a)

a. $U \rightarrow S : U, h(P)$

▼ Risposta

Sbagliata, non si raccomanda questa versione perché la proprietà di autenticazione non viene garantita. Un attaccante potrebbe intercettare, leggere ed archiviare il messaggio scambiato e riutilizzarlo in un secondo momento per un replay attack autenticandosi così sul server come l'utente U.



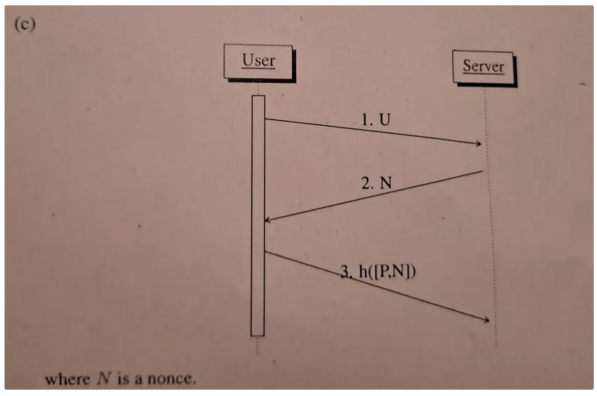
(b)

where S_U is a number (salt) uniquely associated to user U and every user U has her own unique salt S_U.

b. 1. $U \rightarrow S : U$
2. $S \rightarrow U : S_U$
3. $U \rightarrow S : h([P, S_U])$

▼ Risposta

Sbagliata, non si raccomanda questa versione nonostante sia migliore di quella precedente in quanto, anche qui, la proprietà di autenticazione che sembra essere garantita non lo è. Essendo S_U un valore univoco per utente, ergo che non cambia mai una volta generato, apre il fianco ad un attacco di tipo replay attack da parte di un attaccante che potrebbe intercettare, leggere ed archiviare il terzo messaggio per riutilizzarlo in un secondo momento per autenticarsi sul server come utente U.



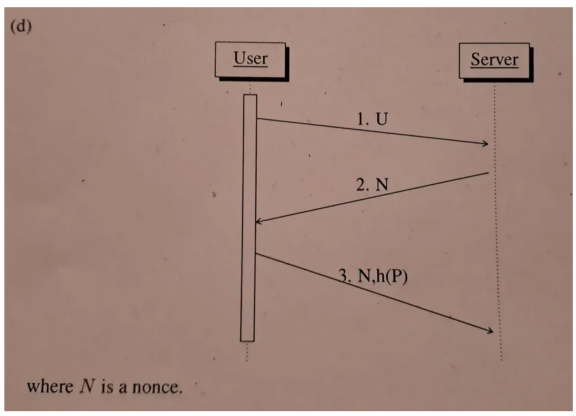
(c)

where N is a nonce.

c. 1. $U \rightarrow S : U$
2. $S \rightarrow U : N$
3. $U \rightarrow S : h([P, N])$

▼ Risposta

Corretta, tra le versioni presentate questa è quella più raccomandabile in quanto il valore del nonce cambia ad ogni richiesta di autenticazione e solo l'utente U può generare il messaggio h(P||N) verificando, così, la proprietà di autenticazione.



(d)

where N is a nonce.

d. 1. $U \rightarrow S : U$
2. $S \rightarrow U : N$
3. $U \rightarrow S : N, h(P)$

▼ Risposta

Sbagliata, non si raccomanda questa versione. Il valore di N generato dal server viene passato solamente in chiaro e non usato all'interno dell'hash per dargli autenticazione.

Settembre 2022

1. **Cryptography**

An encryption device C has a master key K_C stored in it. K_C is not accessible from outside. Since C must encrypt with other keys (besides K_C) and it not possible to store all keys inside C, the additional keys are encrypted with K_C and stored outside C. Each key K is associated with a bit vector P_K indicating how K can be used (e.g. for encryption, for authentication, ... or a combination thereof).

C must use the key K according to the allowed usage encoded in the corresponding bit vector P_K. Thus, when K and P_K are exported and stored outside C it is not enough to store the pair $\langle\{K\}_{K_C}, P_K\rangle$, as otherwise an attacker could modify the values of P_K. A possible solution is to use P_K in the encryption and decryption process in such a way that if P_K is modified, the recovery of K by C must generate an unusable result.

For each of the following procedures indicate whether the procedure is adequate to the purpose. Please justify your answer.

In what follows, $\oplus$ denotes the bit-wise exclusive or (XOR) and we assume that K_c, K, P_K have all the same length.

1. $(\{K \oplus P_K\}_{K_C}, P_K)$
   - ▼ Risposta

     NOT ADEQUATE

     The procedure is not adequate since XOR-ing **K** directly with **P_K** allows an attacker to modify the key **K** and change its usage, liK_c transforming an encryption key into a decryption key.

   - ▼ Risposta nostra

     Questa procedura **NON** è adatta allo scopo in quanto un attaccante potrebbe modificare la coppia archiviata sostituendo P_K con un P'_K diverso, rendendo il recupero della chiave K originale impossibile, tuttavia la nuova chiave K' ottenuta da $K \oplus P_K \oplus P'_K$ verrebbe ancora interpretata come chiave valida per l'operazione indicata da P'_K e risulterebbe, quindi, utilizzabile per uno scopo diverso da quello originariamente previsto. Si ricorda che C conosce solo K_C, non ha memoria delle varie chiavi K che ha cifrato.

2. $(\{K\}_{K_C \oplus P_K}, P_K)$
   - ▼ Risposta

     ADEQUATE

     This procedure is adequate because if **P_K** is modified, the resulting key **K** would be different, and decrypting **{{K}}K_c** would give a different result since it wouldn't be decrypted with the same key it was originally encrypted with.

   - ▼ Risposta nostra

     Questa procedura **E'** adatta allo scopo in quanto una eventuale modifica di P_K con un P'_K diverso renderebbe il recupero di K impossibile non potendo decifrare più il primo elemento della coppia archiviata, infatti andandolo a decifrare la decifratura fallirebbe. Questa è l'unica versione dove, chi conosce K_C, si può rendere effettivamente conto della modifica apportata a P_K perchè, sapendo che la chiave di decifratura è ottenuta da $K_C \oplus P_K$, facendo l'operazione $K_C \oplus P_K \oplus P_K$ dovrebbe riottenere K_C che conosce, se P_K fosse modificato in P'_K allora l'operazione $K_C \oplus P_K \oplus P'_K$ restituirebbe K'_C diverso da K_C.

3. $(\{K\}_{K_C} \oplus P_K, P_K)$
   - ▼ Risposta

     ADEQUATE

     Since we 're XOR-ING an Encrypted text, if we careless.. change P_k , we could once get un usable text.

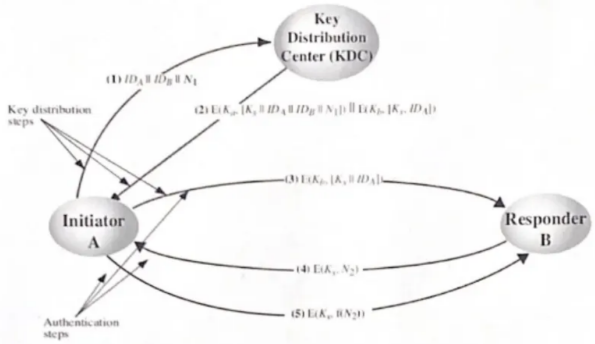
   - ▼ Risposta nostra

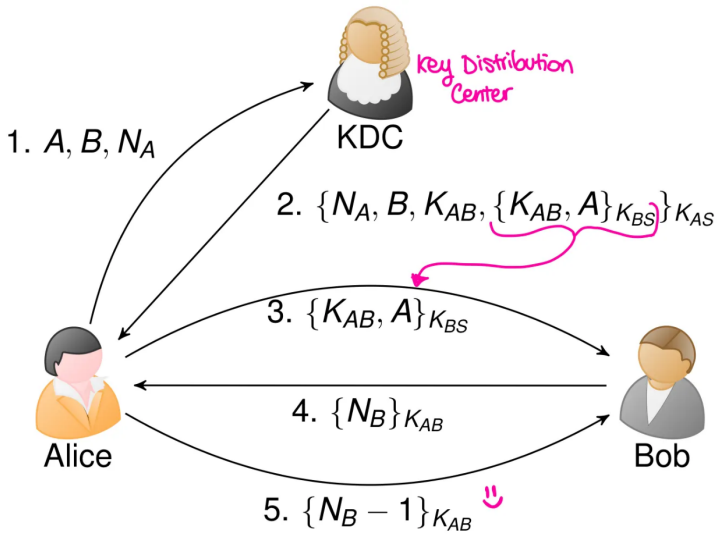
     Questa procedura **NON** è adatta allo scopo in quanto un attaccante potrebbe modificare, nella coppia archiviata, i due P_K con due P'_K, mantenendo inalterata K che risulterebbe ancora recuperabile ma utilizzabile per uno scopo diverso da quello originariamente previsto.

Luglio 2022

3. **Security Protocols**

What is the main purpose of the last two messages in the Needham-Schroeder symmetric key protocol?





- ▼ Risposta

  E' letteralmente contenuta nella immagine mostrata, ossia servono ai due utenti, Alice e Bob, che partecipano alla comunicazione di autenticarsi a vicenda.

Febbraio 2022

Consider the following authentication protocol

1. $A \rightarrow B : E(K, [A, B, T])$

where K is a key shared between A and B and T is a time-stamp generated by A.

a. Indicate which of the following security properties are met by the protocol. For the properties that are met by the protocol describe the assumptions that must hold for the property to hold. For the properties that are not met by the protocol write an execution trace witnessing the violation of the property.

   a. A authenticates B

   ~~b.~~ B authenticates A

   c. Secrecy of N

   ~~d.~~ Secrecy of K

- ▼ **Soluzione**

  a. A authenticates B → A non può autenticare B in quando non riceve da egli nessuna risposta in questo protocollo.

  b. B authenticates A → Si deve assumere che K sia una chiave condivisa e conosciuta solo da A e B, inoltre il timestamp dev'essere sufficientemente recente per evitare replay attacks.

  c. Secrecy of N → Non c'è nessuna N all'interno del messaggio.

  d. Secrecy of K → K dev'essere conosciuta solo da A e B e non facilmente determinabile conoscendo il protocollo ed il contenuto dei messaggi scambiati. (es. se $K = A \oplus B$)

a. Describe the actions carried out by B upon receipt of the message for a proper functioning of the protocol.

- ▼ **Risposta**

  B usa la chiave condivisa K per decriptare il messaggio e leggerne il contenuto, verificherà che il primo identificativo indicherà il mittente, ossia A, il secondo identificativo indicherà che il messaggio era destinato a lui, ossia B, e che il timestamp T sia sufficientemente recente per assicurare freschezza del messaggio.

c. What are the consequences of using an implementation of the protocol where the timestamp is very coarse, e.g. successive time instants correspond to large intervals (say several seconds).

- ▼ **Risposta**

  Se un attaccante intercettasse il messaggio potrebbe riutilizzarlo per replay attack.

d. Assume that successive time instants correspond to 1 second and that timestamps are represented by 16 bits. How long must an attacker wait to mount a replay attack?

- ▼ **Risposta**

  L'attaccante dovrà attendere 2^{16} secondi affinchè il timestamp ritorni ad avere lo stesso valore ed esser ritenuto valido dal destinatario.

Gennaio 2022

3. Security Protocols

The CRAM-MD5 (Challenge-Response Authentication Mechanism) protocol, used to provide authentication to the IMAP4 email protocol, consists of the following steps:

1. $C \to S : C$
2. $S \to C : N \| T \| S$
3. $C \to S : U, H(K \| T)$

where C is the client, S the server, N a nonce, T a timestamp, U is the username, K is a cryptographic key derived from the user's password and H is a cryptographic hash function (MD5). The goal of the protocol is to allow S to authenticate C. It is obviously assumed that S knows K.

(a) It the timestamp T necessary? Please justify your answer.

(b) It the nonce N necessary? Please justify your answer.

1. **Is the timestamp T necessary? Please justify your answer.**

   ▼ Risposta

   Sì. Il timestamp è necessario per evitare attacchi di tipo replay e reflection. Senza il timestamp un attaccante potrebbe riutilizzare un precedente messaggio intercettato, considerato valido per l'autenticazione, in un secondo momento per ottenere un accesso non autorizzato.

2. **Is the nonce N necessary? Please justify your answer.**

   ▼ Risposta

   Non è strettamente necessario. Per com'è definito il protocollo, il nonce non viene usato per validare o autentificare nulla, viene solamente passato dal server al client nel messaggio 2, se fosse usato correttamente svolgerebbe la stessa funzione del timestamp. Può comunque tornare utile quando client e server non hanno entrambi degli orologi interni o questi non sono sincronizzati tra di loro, oppure per gestire più richieste (aka istanze di protocollo) simultanee nello stesso istante di tempo per identificarle univocamente.

Luglio 2009

Si consideri il seguente protocollo per l'autenticazione di due agenti in possesso di una chiave simmetrica condivisa K.

1. $A \to B : N \oplus K$
2. $B \to A : N$

Il primo agente A genera una nonce N della stessa lunghezza di K, la mette in $\oplus$ con K e la invia al secondo agente B.

Quando B riceve il messaggio da A, lo mette in $\oplus$ con la chiave K e manda la stringa di bit risultante indietro ad A.

Se la stringa di bit ricevuta da A coincide con la nonce generata inizialmente, allora A può concludere di aver autenticato B.

a. Si indichino almeno due proprietà che sono fondamentali per la sicurezza di un protocollo di autenticazione di questo tipo.

   ▼ Soluzione

   - Autenticazione di B nei confronti di A
   - Segretezza della chiave K

b. Si discuta se le proprietà indicate sono soddisfatte dal protocollo in questione.

   ▼ Soluzione

   La chiave K viene compromessa. Infatti, mettendo in $\oplus$ i messaggi scambiati durante l'esecuzione del protocollo si ottiene la chiave K.

Giugno 2009

Si consideri il protocollo di autenticazione a chiave pubblica di Needham Schroeder:

1. $A \to B : \{A, N_A\}_{K_B}$
2. $B \to A : \{N_A, N_B\}_{K_A}$
3. $A \to B : \{N_B\}_{K_B}$

Come visto a lezione tale protocollo è vulnerabile ad un attacco man-in-the-middle.

Dire quali delle seguenti varianti del protocollo impediscono tale attacco e quali invece continuano a soffrirne. Si giustificano le risposte date.

▼ **Spoiler attacco MITM**

Man-In-The-Middle

1. $A \to C : \{A, N_A\}_{K_C}$
2. $C \to B : \{A, N_A\}_{K_B}$
3. $B \to C : \{N_A, N_B\}_{K_A}$ B pensa sia A
4. $C \to A : \{N_A, N_B\}_{K_A}$
5. $A \to C : \{N_B\}_{K_C}$
6. $C \to B : \{N_B\}_{K_B}$

C si è autenticato con B come se fosse A. Questo attacco funziona quando A vuole realmente comunicare con C ma C è malevolo.

Gennaio 2019

The following protocol has been designed to generate and distribute a session key K between A and B using S as key distribution center:

1. $A \to S : E(K_{AS}, B)$
2. $S \to A : E(K_{AS}, [K, E(K_{BS}, [A, K])])$
3. $A \to B : E(K_{BS}, [A, K])$

where K_{AS} is a symmetric key known only to A and S and K_{BS} is a symmetric key known only to B and S.

The protocol is vulnerable to a replay attack.

a. Describe an attack.

   ▼ Soluzione

   - Primo attacco: Un attaccante potrebbe origliare il terzo messaggio, dato che non contiene informazioni riguardo la sua freschezza può essere riusato in un secondo momento per proporre a B una chiave condivisa K vecchia così da convincerlo a cifrare tutto con essa, aumentando le possibilità di trovare K con un attacco di tipo critto-analisi.
   - Secondo attacco: Se Alice volesse di nuovo comunicare con Bob in una nuova sessione, un attaccante potrebbe origiliare e copiare il secondo messaggio così da rimandarlo ad Alice in un secondo momento su sua richiesta, mettendosi al posto del server. Come nel primo attacco l'attaccante lo fa per costringere Alice e Bob ad usare una chiave condivisa K vecchia.

b. Assume that A, B and S have synchronized clocks. Modify the protocol so to prevent replay attacks by adding values to the messages of the protocol. Please justify your answers.

   ▼ Soluzione

   1. $A \to S : E(K_{AS}, B)$
   2. $S \to A : E(K_{AS}, [K, T, E(K_{BS}, [A, K, T])])$
   3. $A \to B : E(K_{BS}, [A, K, T])$

   dove T è un timestamp generato da A e controllato da S e B.

1.

   a. $A \to B : \{A, B, N_A\}_{K_B}$
   b. $B \to A : \{N_A, N_B\}_{K_A}$
   c. $A \to B : \{N_B\}_{K_B}$

   ▼ Soluzione

   L'attacco è ancora possibile, all'attaccante C basta levare l'identificatore B al primo messaggio dopo averlo spacchettato con la sua chiave K_C.

2.

   a. $A \to B : \{A, B, N_A\}_{K_B}$
   b. $B \to A : \{N_A, N_B, B\}_{K_A}$
   c. $A \to B : \{N_B\}_{K_B}$

   ▼ Soluzione

   L'attacco non è più possibile in quanto nel messaggio 2 A si renderà conto che l'identificativo di B sarà diverso da quello di C con cui credeva di star comunicando.

3.

   a. $A \to B : \{A, B, N_A\}_{K_B}$
   b. $B \to A : \{N_A, N_B\}_{K_A}$
   c. $A \to B : \{A, B, N_B\}_{K_B}$

   ▼ Soluzione

   L'attacco è ancora possibile per le stesse ragioni del punto 1, l'attaccante, spacchettando i messaggi provenienti da A, li può liberamente manipolare e rimuovere gli identificativi di B.

Luglio 2008

Si consideri il Needham-Schroeder Shared-Key (NSSK) protocol presentato a lezione:

1. $A \to S : A, B, N_a$
2. $S \to A : \{N_a, B, K_{AB}, \{K_{AB}, A\}_{K_{BS}}\}_{K_{AS}}$
3. $A \to B : \{K_{AB}, A\}_{K_{BS}}$
4. $B \to A : \{N_b\}_{K_{AB}}$
5. $A \to B : \{N_b - 1\}_{K_{AB}}$

dove N_a e N_b sono nonces, K_{AS} è la long term key tra A e S e K_{BS} è la long term key
tra B e S e K_{AB} e una nuova chiave di sessione.

Si assuma che il key server S sia fidato.

L'obiettivo del protocollo e di generare una nuova chiave di sessione K_{AB} e far sì che sia condivisa tra A e B.

Siccome K_{AB} può essere utilizzata per cifrare grosse moli di dati, al fine di contrastare possibili tentativi di ricostruirla tramite crittoanalisi, K_{AB} viene usata per un certo lasso di tempo scaduto il quale il protocollo viene rieseguito per generare una nuova chiave di sessione.

a. Si consideri la versione del protocollo NSSK ottenuta eliminando la nonce N_A dai primi
due messaggi, ovvero:

1. $A \to S : A, B$
2. $S \to A : \{B, K_{AB}, \{K_{AB}, A\}_{K_{BS}}\}_{K_{AS}}$
3. $A \to B : \{K_{AB}, A\}_{K_{BS}}$
4. $B \to A : \{N_b\}_{K_{AB}}$
5. $A \to B : \{N_b - 1\}_{K_{AB}}$

e si discutano le possibili conseguenze negative di questa semplificazione.

▼ Soluzione

A non e più in grado di stabilire la freschezza della chiave K_{AB} ricevuta da S al passo 2. Un attaccante C potrebbe, dunque, intercettare il messaggio mandato al passo 2 da S ad A e mandare al suo posto una vecchia versione dello stesso, contenente una chiave di sessione che C è riuscito nel frattempo a ricostruire tramite crittoanalisi.

b. Si dimostri che anche il protocollo originale è vulnerabile ad un attacco simile a quello discusso nella domanda (a) e si discutano possibili modifiche al protocollo per prevenire tale attacco.

▼ Soluzione

B non ha modo di verificare la freschezza del messaggio che riceve al passo 3 e quindi è vulnerabile ad un attacco di tipo replay ove un attaccante gli invia un messaggio dello stesso tipo precedentemente inviato e di cui è riuscito a ricostruire la chiave di sessione in esso contenuta.

Una possibile soluzione e quella adottata in Kerberos, con l'aggiunta di un timestamp
al messaggio scambiato al passo 3. Il protocollo risultante è:

1. $A \to S : A, B, N_a$
2. $S \to A : \{N_a, B, K_{AB}, \{T, K_{AB}, A\}_{K_{BS}}\}_{K_{AS}}$
3. $A \to B : \{T, K_{AB}, A\}_{K_{BS}}$
4. $B \to A : \{N_b\}_{K_{AB}}$
5. $A \to B : \{N_b - 1\}_{K_{AB}}$

Ovviamente ciò comporta che B abbia un clock sincronizzato con S e quando riceve il
messaggio al passo 3 deve verificare che T non sia troppo vecchia.

Giugno 2008

1. Si consideri il seguente protocollo di sicurezza P_1 per l'autenticazione tra due agenti A e B:

1. $A \to B : N_a$
2. $B \to A : \{N_a\}_{K_{ab}}, N_b$
3. $A \to B : \{N_b\}_{K_{ab}}$

dove N_a e N_b sono nonces e K_{ab} è una chiave condivisa tra A e B.

a. Si mostri che il protocollo non garantisce la mutua autenticazione.

▼ Soluzione

Soluzione. Il protocollo non garantisce la proprietà di autenticazione mutua. Infatti il protocollo è vulnerabile al seguente *reflection attack*:

$$\begin{array}{llll} (s1) & 1. & a \to i & : n_a \\ (s2) & 1. & a \leftarrow i & : n_a \\ (s2) & 2. & a \to i & : \{n_a\}_{k_{ab}}, n_b \\ (s1) & 2. & a \leftarrow i & : \{n_a\}_{k_{ab}}, n_b \\ (s1) & 3. & a \to i & : \{n_b\}_{k_{ab}} \end{array}$$

dove $s1$ e $s2$ indicano due esecuzioni/sessioni concorrenti del protocollo. A questo punto a è convinto di aver interagito con b, ma ciò non è avvenuto.

b. Una delle regole di prudent engineering per la progettazione di protocolli di sicurezza
presentate a lezione suggerisce di includere nei messaggi l'identità del mittente e del destinatario. Si mostri come l'applicazione di questo principio può prevenire l'attacco
trovato al punto precedente.

▼ Soluzione

Soluzione. Applicando tale principio di *prundent engineering* si ottiene

1. $A \to B : A, B, N_a$
2. $B \to A : \{A, B, N_a\}_{K_{ab}}, N_b$
3. $A \to B : \{A, B, N_b\}_{K_{ab}}$

È facile verificare che l'attacco precedente non è più riproducibile.

c. Un ulteriore metodo per cercare di rendere sicuro il protocollo e quello di modificarlo nel
seguente modo:

1. $A \to B : N_a$
2. $B \to A : \{N_a - 1\}_{K_{ab}}, N_b$
3. $A \to B : \{N_b - 1\}_{K_{ab}}$

Si discuta se questo protocollo garantisce o meno la proprietà di mutua autenticazione.

▼ Soluzione

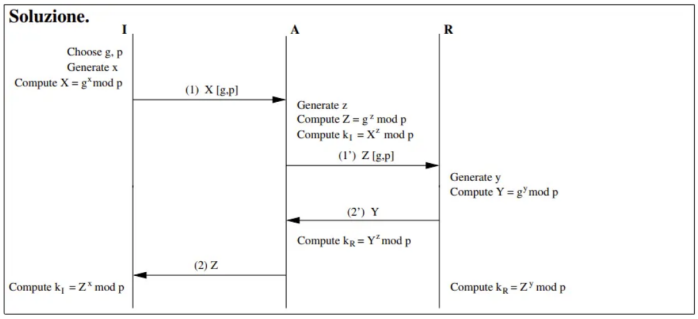
Soluzione. Non la garantisce. Infatti il protocollo continua ad essere vulnerabile allo stesso *reflection attack*:

$$\begin{array}{llll} (s1) & 1. & a \to i & : n_a \\ (s2) & 1. & a \leftarrow i & : n_a \\ (s2) & 2. & a \to i & : \{n_a - 1\}_{k_{ab}} \\ (s1) & 2. & a \leftarrow i & : \{n_a - 1\}_{k_{ab}}, n_b \\ (s1) & 3. & a \to i & : \{n_b - 1\}_{k_{ab}} \end{array}$$

2. Si dimostri che il protocollo per scambio di chiavi di Diffie-Hellman non garantisce l'autenticazione.

▼ Soluzione

Soluzione.



Giugno 2007

5. ***Protocolli di Sicurezza***

Si consideri il seguente protocollo P_1 per la creazione di una chiave condivisa tra due agenti A e B:

$$
\begin{array}{l}
1.\ A \to B : \{A, Na\}_{Kb} \\
2.\ B \to A : \{B, Nb\}_{Ka} \\
3.\ A \to B : \{zero, Msg\}_{Na \oplus Nb} \\
4.\ B \to A : \{one, Msg\}_{Na \oplus Nb}
\end{array}
$$

dove $zero$ e one sono identificatori distinti e $Na \oplus Nb$ è lo XOR bit a bit di Na e Nb.

a. Si descrivano i singoli passi del protocollo e le proprietà di sicurezza per il quale è stato presumibilmente progettato.

▼ Risposta

Soluzione. Il protocollo dovrebbe garantire:

1. la mutua autenticazione tra A e B
2. lo scambio confidenziale di una nuova chiave $Na \oplus Nb$ e di Msg.

b. Si discuta se il protocollo garantisce o meno le proprietà di sicurezza indicate nella risposta alla domanda (a). Si supponga che la crittografia sia perfetta (ovvero non e soggetta ad attacchi di crittoanalisi).

▼ Risposta

Il protocollo non è vulnerabile. La presenza dell'identificatore del mittente nei messaggi inviati ai passi 1 e 2 rende difficile la realizzazione di replay attacks.

La presenza degli identificatori zero e one nei messaggi inviati ai passi 3 e 4 rende difficile la realizzazione di reflection attacks.

Giugno 2006

5. ***Protocolli di Sicurezza***

Si consideri il seguente protocollo:

$$
\begin{array}{l}
(1)\ B \to A : B \\
(2)\ A \to B : \{N_a\}_{K_{ab}} \\
(3)\ B \to A : \{f(N_a)\}_{K_{ab}}
\end{array}
$$

dove K_{ab} è una chiave segreta condivisa da A e B, N_a è un numero generato con un generatore di numeri pseudo-casuali, e f è una funzione nota sia ad A che a B.

Si assuma che l'agente che esegue il protocollo impersonando il ruolo di A non possa eseguire lo stesso protocollo impersonando il ruolo di B. Ad esempio, B potrebbe essere il ruolo giocato dal telecomando della vostra macchina, mentre A quello giocato dal sistema di apertura istallato sulla vostra macchina.

Si discuta perchè la sicurezza del protocollo dipende dal numero di bit utilizzati per rappresentare il numero N_a.

▼ Risposta

Soluzione. Se la nonce non è sufficientemente lunga allora la probabilità che N_a assuma lo stesso valore in esecuzioni successive del protocollo non è trascurabile e un attacker non deve fare altro che osservare e memorizzare un certo numero di coppie di valori $\langle \{N_a\}_{K_{ab}}, \{f(N_a)\}_{K_{ab}} \rangle$ prodotte dal telecomando originale e quindi iniziare il protocollo (facendo finta di essere B, ovvero il telecomando) fino a che A (la macchina) invia un valore $\{N_a\}_{K_{ab}}$ già osservato in precedenza. (Come detto sopra, la probabilità che ciò avvenga è tutt'altro che trascurabile.) A questo punto l'attacker non deve fare altro che inviare il valore trasmesso in precedenza dal telecomando originale in risposta a quella specifica sequenza di bit.

6. ***Protocolli di Sicurezza***

Nel seguente protocollo K_A^1 e K_B^1 sono chiavi pubbliche già note, mentre K_A^2 e K_B^2 sono nuove chiavi pubbliche. N_A e N_B sono nonces.

$$
\begin{array}{ll}
\text{M1.} & A \to B : \{K_A^2, A\}_{K_B^1} \\
\text{M2.} & B \to A : \{N_B, K_B^2\}_{K_A^1} \\
\text{M3.} & A \to B : \{N_B, N_A\}_{K_B^2} \\
\text{M4.} & B \to A : \{N_A\}_{K_A^2}
\end{array}
$$

a. Si descrivano i singoli passi del protocollo e le proprietà di sicurezza per il quale è stato presumibilmente progettato.

▼ Risposta

Soluzione. Nel passo (M1) A manda confidenzialmente la sua nuova chiave pubblica K_A^2 a B. Nel passo (M2) B manda confidenzialmente ad A la sua nuova chiave pubblica K_B^2 ed una nonce N_B per autenticare A. Nel passo (M3) A invia a B in modo confidenziale la nonce N_B ricevuta per autenticarsi e una nuova nonce N_A per autenticare B. Infine nel passo (M4) B rimanda la nonce N_A ad A in modo confidenziale per autenticarsi. Presumibilmente al termine del protocollo A e B si sono mutuamente autenticati; inoltre A dovrebbe essere certo che K_B^2 è una nuova chiave pubblica di B e B dovrebbe essere certo che K_A^2 è una nuova chiave pubblica di A.

2007

4. ***Security Protocols***

Suppose Alice wants to send her Bank a message that includes her promise to pay Charlie $50 dollars. Alice and the Bank have a shared secret X. Alice initiates a conversation with the Bank by sending: $A||B||n$ (Alice's identity, the Bank's identity, and a nonce).

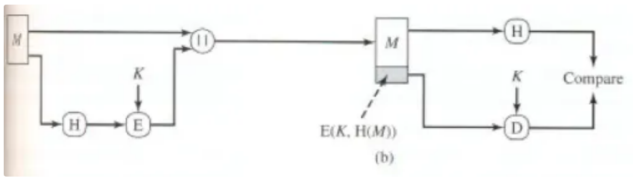
(a) Specify a valid reply for the Bank (i.e., a message generated by the Bank to be sent to Alice) that would enable Alice to verify that the reply came from someone who knows the secret X.

▼ Soluzione

Solution:

$$B \to A : A||B||n||HMAC(X, A||B||n)$$

Correzione: $B \to A : A||B||n||MAC(X, A||B||n)$



(b) In order to setup a secure communication, Alice and the Bank need a secret session key. Suppose that the Bank chooses a session key K by XORing some pseudorandom data with X and includes it with the reply in step (a) above. Extend message (a) to provide the session key to Alice securely as well.

▼ Soluzione

Solution:

$$B \to A : A||B||n||E(X, K)||HMAC(X, A||B||n||K)$$

(c) Now, Alice can submit her message ("Pay Charlie $50 from my account") to the Bank. Write the message in such a way that Charlie cannot replay it (Hint: you will need to add something to the message that the Bank is capable of checking to prevent replay.).

▼ Soluzione

Solution: *Call M the message and include c a counter for the messages in the session. Then*

$$A \to B : A||E(K, M||c)||HMAC(K, A||M||c)$$

protects M's secrecy, ensures that Charlie cannot replay, and protects the integrity of the message.

Correzione: $A \to B : A||E(K, M||T_1)||MAC(K, A||M||T_1)$ con premessa che entrambi devono avere orologi interni sincronizzati.

b. Si discuta se il protocollo garantisce o meno le proprietà di sicurezza descritte alla domanda precedente.

▼ Risposta

Soluzione. Non le garantisce, come mostrato dalla seguente traccia di esecuzione, al cui termine B è convinto che K_I^2 sia una chiave pubblica di A.

$$
\begin{array}{lll}
A \to & I & : \{K_A^2, A\}_{K_I^1} \\
 & I \to B & : \{K_I^2, A\}_{K_B^1} \\
 & I \leftarrow B & : \{N_B, K_B^2\}_{K_A^1} \\
A \leftarrow & I & : \{N_B, K_B^2\}_{K_A^1} \\
A \to & I & : \{N_B, N_A\}_{K_B^2} \\
 & I \to B & : \{N_B, N_A\}_{K_B^2} \\
 & I \leftarrow B & : \{N_A\}_{K_I^2} \\
A \leftarrow & I & : \{N_A\}_{K_A^2}
\end{array}
$$

c. Nel caso sia stata individuata una vulnerabilità, si identifichi un raffinamento del protocollo che non soffre di tale vulnerabilità.

▼ Soluzione

Errata Corrige: La modifica proposta non risolve il problema. Infatti anche questa variante del protocollo soffre dello stesso tipo di attacco.
Il problema risiede nel messaggio $\{K_A^2, A\}_{K_B^1}$ inviato da A a B al passo M1. Questo messaggio asserisce implicitamente che K_A^2 è una nuova chiave pubblica di A, ma B non ha modo di verificare l'autenticità di tale informazione. La soluzione è cambiare tale messaggio in $\{K_A^2, A\}_{inv(K_A^1)}$, dove $inv(K_A^1)$ è la chiave privata corrispondente alla chiave pubblica K_A^1. Questo messaggio è a tutti gli effetti un certificato emesso da A (usando la chiave pubblica K_A^1) in cui viene asserito che K_A^2 è una (nuova) chiave pubblica di A.

Luglio 2006

6. ***Protocolli di Sicurezza***

Si consideri il seguente protocollo P_1 utilizzato in ambito di telefonia mobile

$$(1)\ B \to M : B, K_B$$
$$(2)\ M \to B : \{K\}_{K_B}$$
$$(3)\ M \to B : \{M, P\}_K$$

dove M è un terminale mobile con limitate capacità di calcolo, B è la stazione base, K_B è una chiave pubblica di B non nota a M, K è una chiave segreta per crittografia simmetrica generata da M e P una password nota solo a M e a B. Ogni qualvolta viene completato il protocollo la stazione B addebita a M un costo prestabilito.

a. Si descrivano i singoli passi del protocollo e le proprietà di sicurezza per il quale e stato presumibilmente progettato.

▼ Risposta

Soluzione. Al passo 1 B comunica a M la propria identità e la propria chiave pubblica K_B. Al passo 2 M genera la chiave segreta K e la invia confidenzialmente a B. Siccome B non può essere ancora certo che K provenga da M, nel passo 3 M invia a B in modo confidenziale la propria identità M e la password P. A questo punto B è certo che K sia stata effettivamente generata da M (graze al messaggio ricevuto al passo 3) e che non è nota ad altri (grazie al messaggio ricevuto al passo 2). L'obiettivo del protocollo è dunque quello di stabilire una chiave di sessione tra M e B. Più in generale, il protocollo dovrebbe garantire:

1. la confidenzialità di K e P,
2. l'autenticazione di M nei confronti di B (entity authentication). Quest'ultima proprietà è importante per evitare *replay attacks*, qui particolarmente importante in quanto ad ogni esecuzione del protocollo viene effettuato un addebito.

b. Spiegare una ragione per cui il protocollo P1 è preferibile al seguente protocollo P2 che, pur garantendo le stesse proprietà di sicurezza, e indiscutibilmente più semplice.

$$(1)\ B \to M : B, K_B$$
$$(2)\ M \to B : \{K, M, P\}_{K_B}$$

▼ Risposta

K è inutile qui

Soluzione.
Perchè P_2 richiede che M applichi cifratura a chiave pubblica a un plaintext più lungo. Essendo M un dispositivo con limitate capacità computazionali, P_1 è preferibile a P_2.

c. Si discuta se il protocollo garantisce o meno le proprietà di sicurezza indicate nella risposta alla domanda (a).

▼ Risposta

Soluzione. La confidenzialità sia di K e di P non sono garantite come mostrato dal seguente attacco:

$$\begin{array}{lll} B \to & I & : B, K_B \\ & I \to M & : B, K_I \\ & I \leftarrow M & : \{K\}_{K_I} \\ B \leftarrow & I & : \{K\}_{K_B} \\ & I \leftarrow M & : \{M, P\}_K \\ B \leftarrow & I & : \{M, P\}_K \end{array}$$

Neppure la entity authentication è garantita, come mostrato dal seguente (ancor più semplice) attacco:

$$\begin{array}{lll} B \to & I \to M & : B, K_B \\ B \leftarrow & I \leftarrow M & : \{K\}_{K_B} \\ B \leftarrow & I \leftarrow M & : \{M, P\}_K \\ & \vdots & \\ B \to & I & : B, K_B \\ B \leftarrow & I & : \{K\}_{K_B} \\ B \leftarrow & I & : \{M, P\}_K \end{array}$$

dove l'intruder dopo aver osservato una normale esecuzione del protocollo "rigioca" i messaggi $\{K\}_{K_B}$ e $\{M, P\}_K$ osservati in precedenza facendo addebitare un ulteriore costo a M senza che questo abbia preso parte alla seconda esecuzione del protocollo eseguita da B. Si noti che in questo semplice caso, la confidenzialità di K e B non è violata.

d. Nel caso sia stata individuata una vulnerabilità, si identifichi un raffinamento del protocollo che non soffre di tale vulnerabilità.
A tal fine si assuma che:

- B sia in possesso di un certificato $\{B, K_B\}_{K_{CA}^{-1}}$ emesso da un'autorità di certificazione CA relativo alla propria chiave pubblica K_B e
- M sia in possesso di K_{CA}, ovvero della chiave pubblica di CA.

▼ Soluzione

Soluzione. Se B al passo 1 trasmette il certificato $\{B, K_B\}_{K_{CA}^{-1}}$ allora M ha modo di verificare l'autenticità di K_B e il primo dei due attacchi mostrati in precedenza non è più possibile.

$$(1)\quad B \to M : \{B, K_B\}_{K_{CA}^{-1}}$$
$$(2)\quad M \to B : \{K\}_{K_B}$$
$$(3)\quad M \to B : \{M, P\}_K$$

Per far sì che il protocollo non sia soggetto a replay attacks è sufficiente realizzare il solito meccanismo di challenge-response mediante una nonce come indicato qui di seguito:

$$(1)\quad B \to M : N_B, \{B, K_B\}_{K_{CA}^{-1}}$$
$$(2)\quad M \to B : \{K\}_{K_B}$$
$$(3)\quad M \to B : \{N_B, M, P\}_K$$